
Wireshark: TLS i DTLS

U ovoj će se vježbi istražiti protokol TLS (*Transport Layer Security*) i njegova varijanta DTLS (*Datagram Transport Layer Security*). Protokol TLS je u starijoj varijanti protokola poznat kao SSL (*Secure Sockets Layer*) pa se i danas često koristi kratica SSL i kada se misli na TLS.

Vježba je razdvojena u dva dijela. U prvom se analizirati mrežni promet koji koristi TCP, TLS i HTTP, a u drugom snimka prometa u kojoj se koristi UDP, DTLS, a na aplikacijskom sloju se prenose ASCII kodirane tekstualne poruke. U drugom dijelu vježbe na raspolaganju su i kriptografski ključevi koji omogućuju čitanje kriptiranog sadržaja TLS/DTLS poruka.

I. TLS kao dio HTTPS-a

U prvom se dijelu istražuje mrežni promet razmijenjen između klijenta i poslužitelja koji koriste TLS za osiguravanje weba. Takva kombinacija TLS-a i HTTP-a se označava kraticom HTTPS (*HTTP over TLS*, *HTTP over SSL*, *HTTP Secure*). Istražit će se različiti tipovi TLS-ovih zapisa koji se razmjenjuju, ali se stvarni sadržaj poruka ne može čitati jer su poruke kriptirane.

Važno je znati da TLS 1.3 radi dosta drugačije od prethodnih verzija (TLS 1.2 i starije). Kako je TLS 1.2 još uvijek vrlo rasprostranjen, a TLS 1.3 je aktualna verzija, možete prvi dio vježbe napraviti s bilo kojom od te dvije verzije. Svakako zabilježite koju ste verziju TLS-a analizirali i toj verziji prilagodite vježbu.

Na kraju prvog dijela svakako odgovorite na pitanja (bez obzira na to koju verziju protokola analizirate).

- A) Koju verziju protokola ste analizirali?
 - B) Koja se je metoda koristila za razmjenu ključeva (RSA, DH, ...)
 - C) Koji asimetrični algoritam se koristi u certifikatu (ako certifikat nije kriptiran – ovisno o verziji TLS-a)? Ako je, onda tu situaciju prokomentirati!
 - D) Koji se simetrični algoritam koristi za kriptiranje podataka?
 - E) Radi li se o običnom načinu uspostavljanja sjednice/razgovora TLS-a ili o 0-RTT varijanti?
- Objasniti odgovor.

Pri analizi protokola svakako koristite prezentacije s predavanja! Primjer pitanja koja vas vode kroz analizu napravljena su za TLS do verzije 1.2. Ako analizirate TLS 1.3 prilagodite analizu u skladu sa porukama koje definira protokol. Prema potrebi konzultirajte i adekvatni RFC standard.

Nemojte se zbuniti ako TLS 1.3 za record type kod ClientHello navodi verziju 1.0, a za ostale poruke 1.2 verziju zapisa. Tako zahtjeva standard radi unazadne kompatibilnosti.

1. Snimanje TLS-ove sjednice

Prvi je korak snimiti pakete koji se razmjenjuju unutar TLS-ove sjednice. Da biste to ostvarili možete primjerice posjetiti neko sjedište za web trgovinu na kojem možete započeti postupak kupnje proizvoda. (Postupak ćete naravno prekinuti prije same kupnje proizvoda!) TLS-ov promet moguće je snimiti i kada se koristi Googleova tražilica koja koristi TLS da bi sakrila sadržaj pretraživanja od treće strane i tako povećala privatnost. Nakon snimanja paketa u Wiresharku namjestite filter da prikazuje samo okvire koji sadrže TLS-ove zapise koje je poslalo i primilo vaše računalo. (TLS-ov zapis je isto što i TLS-ova poruka.)

2. Analiza snimljenih paketa

Prilikom analize prometa važno je imati na umu da Ethernetov okvir može sadržavati jedan ili više TLS-ovih zapisa. Također, jedan TLS-ov zapis ne mora stati u jedan Ethernetov okvir. U tom slučaju treba više Ethernetovih okvira za prijenos jednog TLS-ovog zapisa.

Kada odgovarate na pitanja, navedite osnovni sadržaj paketa na temelju kojega odgovarate ili barem označite o kojem se paketu radi (npr. redni broj paketa u snimci prometa koju prilažete uz izvještaj).

1. Za prvih 8 Ethernetovih okvira navedite tko je poslao okvir (klijent ili poslužitelj), odredite broj TLS-ovih zapisa sadržanih u tom okviru te navedite tipove TLS-ovih zapisa sadržanih u okviru. Nacrtajte vremenski dijagram razmjene TLS-ovih zapisa između klijenta i poslužitelja sa jednom strelicom za svaki TLS-ov zapis.
2. Svaki TLS-ov zapis započinje s tri polja (u kojima mogu biti zapisane različite vrijednosti). Jedno od tih polja je *content type* ("tip sadržaja") i zauzima jedan bajt. Navedite sva tri polja i njihove duljine.

Zapis *ClientHello*:

3. Proširite zapis *ClientHello*. (Ako snimka sadrži više zapisa tipa *ClientHello*, tada proširite pogled za prvi okvir koji sadrži taj zapis.) Koja je vrijednost polja *content type*?
4. Sadrži li zapis tipa *ClientHello nonce* (poznat i kao "challenge" odn. "izazov")? Ako sadrži koja je njegova vrijednost (zapišite u heksadekadskom obliku)?
5. Oglašava li klijent u zapisu *ClientHello* kriptografske skupove koje podržava? Ako da, tada za prvi kriptografski skup u listi zapišite koji se algoritam asimetričnog kriptiranja koristi, koji algoritam simetričnog kriptiranja te koji algoritam za sigurnosnu funkciju sažimanja?

Zapis *ServerHello*:

6. Pronađite zapis *ServerHello*. Sadrži li ovaj zapis odabrani kriptografski skup? Koje se algoritmi koriste u odabranom kriptografskom skupu?
7. Sadrži li ovaj zapis *nonce*? Ako sadrži, koliko je bajtova dugačak? Koja je svrha korištenja klijentskog i poslužiteljskog broja *nonce* u TLS-u?
8. Sadrži li ovaj zapis identifikator sjednice (*session ID*)? Koja je svrha polja *session ID*?
9. Sadrži li ovaj zapis certifikat ili se certifikat nalazi u odvojenom zapisu. Stane li certifikat u jedan Ethernetov okvir?

Zapis *Client Key Exchange*:

10. Pronađite zapis *client key exchange*. Sadrži li ovaj zapis pred-glavu tajnu? Za što se ta tajna koristi? Je li ta tajna kriptiranja? Ako je, kako je kriptirana? Koliko je velika kriptirana tajna?

Zapisi *Change Cipher Spec* (poslan od klijenta) i *Encrypted Handshake*:

11. Koja je svrha zapisa *Change Cipher Spec*? Koliko je velik taj zapis u snimci mrežnog prometa?
12. Što je kriptirano u zapisu *encrypted handshake*? Kako?
13. Šalje li i poslužitelj zapise *change cipher* i *encrypted handshake* klijentu? Kako se ti zapisi razlikuju od zapisa koje je poslao klijent?

Tip sadržaja *Application Data*

14. Kako su aplikacijski podaci kriptirani? Sadrže li zapisi s kriptiranim aplikacijskim podacima i MAC? Razlikuje li Wireshark kriptirane aplikacijske podatke i MAC?
15. Komentirajte i objasnite bilo što drugo zanimljivo što ste pronašli u snimci TLS-ove sjednice.

II. DTLS i čitanje kriptiranog sadržaja

Za potrebe ovih vježbi načinjena je jednostavna aplikacija koja se sastoji od klijenta i poslužitelja. Klijent uspostavlja komunikaciju s poslužiteljem koristeći UDP i DTLS te šalje poslužitelju tekstualne poruke kodirane po ASCII standardu. Uz pomoć te aplikacije snimljen je mrežni promet koji će se istraživati u ovoj vježbi.

1. Učitavanje snimke mrežnog prometa u Wireshark

U Wireshark učitati snimku prometa nalazi koja se nalazi u datoteci `WiresharkLab_DTLS.pcapng`. Snimljen je promet između klijenta (127.0.0.1) i poslužitelja (127.1.2.3). Za komunikaciju se koriste protokoli UDP i DTLS. Nakon uspostave sigurne komunikacije klijent šalje poslužitelju 4 tekstualne poruke (ASCII kodirane).

U slučaju da se sadržaj koji se prenosi unutar UDP protokola ne identificira kao TLS/DTLS (jer se ne koristi neki unaprijed dogovoreni broj porta na temelju kojega bi Wireshark mogao pretpostaviti o kojem se protokolu radi) potrebno je postaviti u Wiresharku da se taj promet interpretira kao DTLS/TLS/SSL. Nakon toga popis paketa trebao bi izgledati slično kao na slici ispod.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	127.0.0.1	127.1.2.3	DTLSv1.0	244	Client Hello
2	0.001370701	127.1.2.3	127.0.0.1	DTLSv1.0	86	Hello Verify Request
3	0.001415291	127.0.0.1	127.1.2.3	DTLSv1.0	260	Client Hello
4	0.001683797	127.1.2.3	127.0.0.1	DTLSv1.0	121	Server Hello
5	0.001733523	127.1.2.3	127.0.0.1	DTLSv1.0	270	Certificate (Fragment)
6	0.001737946	127.1.2.3	127.0.0.1	DTLSv1.0	270	Certificate (Fragment)
7	0.001740877	127.1.2.3	127.0.0.1	DTLSv1.0	270	Certificate (Fragment)
8	0.001745020	127.1.2.3	127.0.0.1	DTLSv1.0	196	Certificate (Reassembled)
9	0.001749283	127.1.2.3	127.0.0.1	DTLSv1.0	67	Server Hello Done
10	0.002343693	127.0.0.1	127.1.2.3	DTLSv1.0	416	Client Key Exchange, Change Cipher Spec, Finished
11	0.004162023	127.1.2.3	127.0.0.1	DTLSv1.0	233	New Session Ticket
12	0.004168663	127.1.2.3	127.0.0.1	DTLSv1.0	56	Change Cipher Spec
13	0.004235856	127.1.2.3	127.0.0.1	DTLSv1.0	119	Finished
14	5.876349872	127.0.0.1	127.1.2.3	DTLSv1.0	103	Application Data
15	19.268160375	127.0.0.1	127.1.2.3	DTLSv1.0	135	Application Data
16	34.570918012	127.0.0.1	127.1.2.3	DTLSv1.0	119	Application Data
17	38.078025158	127.0.0.1	127.1.2.3	DTLSv1.0	103	Application Data

2. Usporedba DTLS-a i TLS koji je namijenjen za TCP

16. Proučiti poruke koje se razmjenjuju u fazi rukovanja i usporedite sa fazom rukovanja iz prvog dijela vježbe gdje ste analizirali TLS u službi HTTPS-a. Ima li DTLS neka dodatna polja u odnosu na TLS? Zašto? Čemu služe ta polja? Zabilježite svoja zapažanja.
17. Jesu li sve poruke koje šalje poslužitelj stigle u pravom redoslijedu? Kako ste to provjerili?
18. Pogledajte možete li otkriti sadržaj poruka koje klijent šalje poslužitelju? Zašto?
19. Koliko je bajtova velika 1.,2., 3. i 4. aplikacijska poruka u kriptiranom obliku?

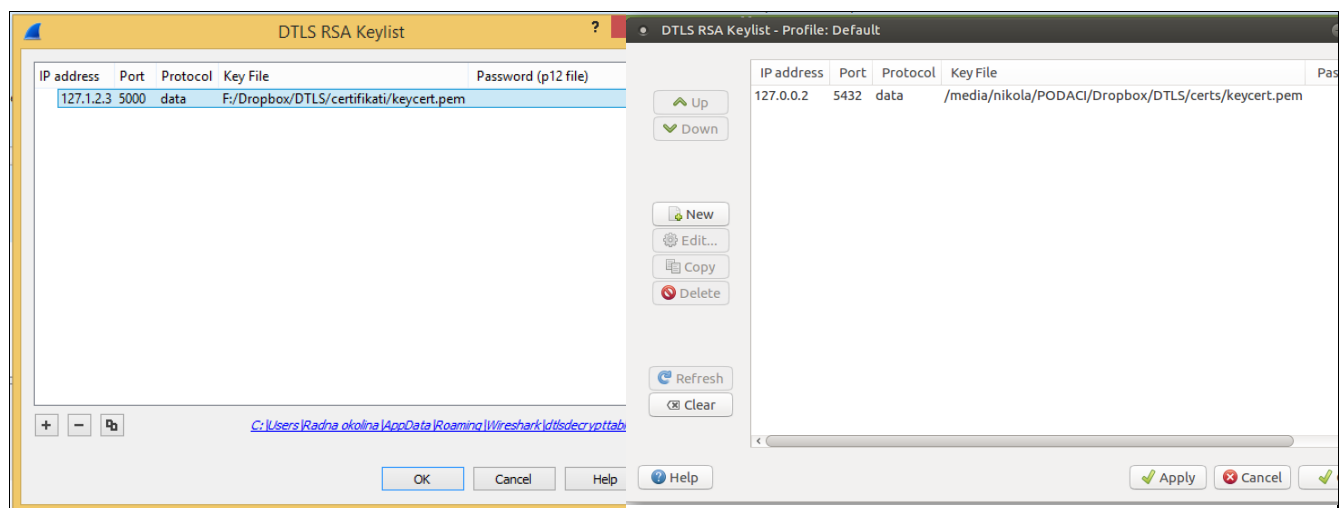
3. Otkrivanje sadržaja kriptiranih poruka koje klijent šalje poslužitelju.

Za dekriptiranje Wiresharku mora biti dostupan tajni ključ koji je korišten u snimljenoj DTLS ili TLS komunikaciji. Wireshark zna protokol rukovanja i ključ može ponovo izvesti¹ ako mu se preda privatan ključ koji koristi poslužitelj te cjelokupna komunikacija kojom je dogovaran tajni ključ.

Privatni RSA ključ potreban za određivanje tajnog AES ključa dogovorenog u DTLS rukovanju nalazi se u priloženoj datoteci tipa .pem.

- U listi paketa kliknuti desnom tipkom miša na bilo koji DTLS paket iz faze rukovanja i pojaviti će se izbornik u kojem treba odabrati "Protocol Preferences > RSA keys list..."
- U listu ključeva dodati da se za promet koji odlazi i dolazi s IP adrese i porta (ili servera ili klijenta u ovoj komunikaciji) dekriptira ključem koji se nalazi u priloženoj datoteci WiresharkLab_keycert.pem i da je teret koji se prenosi tipa "data" tj. da se interpretira kao obični podaci.
- Izgled prozora i način unosa ovih podataka ovisi o verziji Wiresharka i o operacijskom sustavu na kojem se program pokreće. Na slici ispod lijevo prikazan je Wiresharkom dijaloško okvir s popunjenim podacima koji je pokrenut u Windows 10, a u prozoru desno izgled u Ubuntu Mate 16.04. (U slučaju da je Wireshark pokrenut u Windowsima, prazna se polja za upisivanje aktiviraju dvostrukim klikom miša u polje.)

¹ U slučaju kada se *pre-master secret* kriptira javnim ključem poslužitelja. Ako se pak koristi Diffie-Hellmanova metoda tada se Wiresharku mora predati tajni ključ koji je dogovoren za vrijeme komunikacije.



20. Očitajte sadržaj dekriptiranih poruka koje je klijent poslao poslužitelju. Zabilježite sadržaj za sve 4 razmijenjene tekstualne poruke.